

Advertisement

SECURITY



Google says its AI-based
bug hunter found 20
security vulnerabilities

Google Deep

Google's AI-powered bug hunter has just reported its first batch of security vulnerabilities.

Heather Adkins, Google's vice president of security, [announced](#) Monday that its LLM-based vulnerability researcher Big Sleep found and reported 20 flaws in various popular open source software.

Adkins said that Big Sleep, which is developed by the company's AI department DeepMind as well as its elite team of hackers Project Zero, [reported its first-ever vulnerabilities](#), mostly in open source software such as audio and video library FFmpeg and image-editing suite ImageMagick.

IMAGE CREDITS: GOOGLE

Given that the vulnerabilities are not fixed yet, we don't have details of their impact or severity, as Google [does not yet want to provide details](#), which is a standard policy when waiting for bugs to be fixed. But the simple fact that Big Sleep found these vulnerabilities is significant, as it shows these tools are starting to get real results, even if there was a human involved in this case.

"To ensure high quality and actionable reports, we have a human expert in the loop before reporting, but each vulnerability was found and reproduced by the AI agent without human intervention," Google's spokesperson Kimberly Samra told TechCrunch.

Royal Hansen, Google's vice president of engineering, [wrote on X](#) that the findings

TECH DISRUPT

October 27-29, 2025 | San Francisco

Put your brand in front of 10,000+ tech and VC leaders across all three days of Disrupt 2025. Amplify your reach, spark real connections, and lead the innovation charge. Secure your exhibit space before your competitor does.

[Book Your Table >](#)

Most Popular



- Key sections of the US Constitution deleted from government's website
- Instagram takes on Snapchat with new 'Instagram Map'
- Three weeks after acquiring Windsurf, Cognition offers staff the exit door
- Roku launches Howdy, a \$2.99 ad-free streaming service
- Spotify raises subscription prices

demonstrate “a new frontier in automated vulnerability discovery.”

LLM-powered tools that can look for and find vulnerabilities [are already a reality](#). Other than Big Sleep, there’s [RunSybil](#) and XBOW, among others.

TC

Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They’re here to deliver the insights that fuel startup growth and sharpen your edge. Don’t miss the 20th anniversary of TechCrunch Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise on August 7.

San Francisco | October 27-29, 2025

REGISTER NOW

- The uproar over Vogue’s AI-generated ad isn’t just about fashion
- Your public ChatGPT queries are getting indexed by Google and other search engines

XBOW has garnered headlines after [it reached the top](#) of one of the U.S. leaderboards at bug bounty platform HackerOne. It’s important to note that in most cases, these reports have a human at some point of the process to verify that the AI-powered bug hunter found a legitimate vulnerability, as is the case with Big Sleep.

Vlad Ionescu, co-founder and chief technology officer at RunSybil, a startup that develops AI-powered bug hunters, told TechCrunch that Big Sleep is a “legit” project, given that it has “good design, people behind it know what they’re doing, Project Zero has the bug finding experience and DeepMind has the firepower and tokens to throw at it.”

There is obviously a lot of promise with these tools, but also significant downsides. Several people who maintain different software projects have complained of [bug reports that are actually hallucinations](#), with some calling them the bug bounty equivalent of AI slop.

“That’s the problem people are running into, is we’re getting a lot of stuff that looks like gold, but it’s actually just crap,” Ionescu previously told TechCrunch.

Topics: [AI](#) [Big Sleep](#) [cybersecurity](#) [DeepMind](#)

[Google](#) [hackers](#) [infosec](#) [LLMs](#) [Security](#)

[f](#) [X](#) [in](#) [r](#) [✉](#) [🔗](#)



Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity | [X](#) [🦋](#) [m](#)

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

[View Bio](#) >

KEEP READING

SECURITY

[f](#) [X](#) [in](#) [r](#) [✉](#) [🔗](#)

AI slop and fake reports are coming for your bug bounty programs

Lorenzo Franceschi-Bicchierai

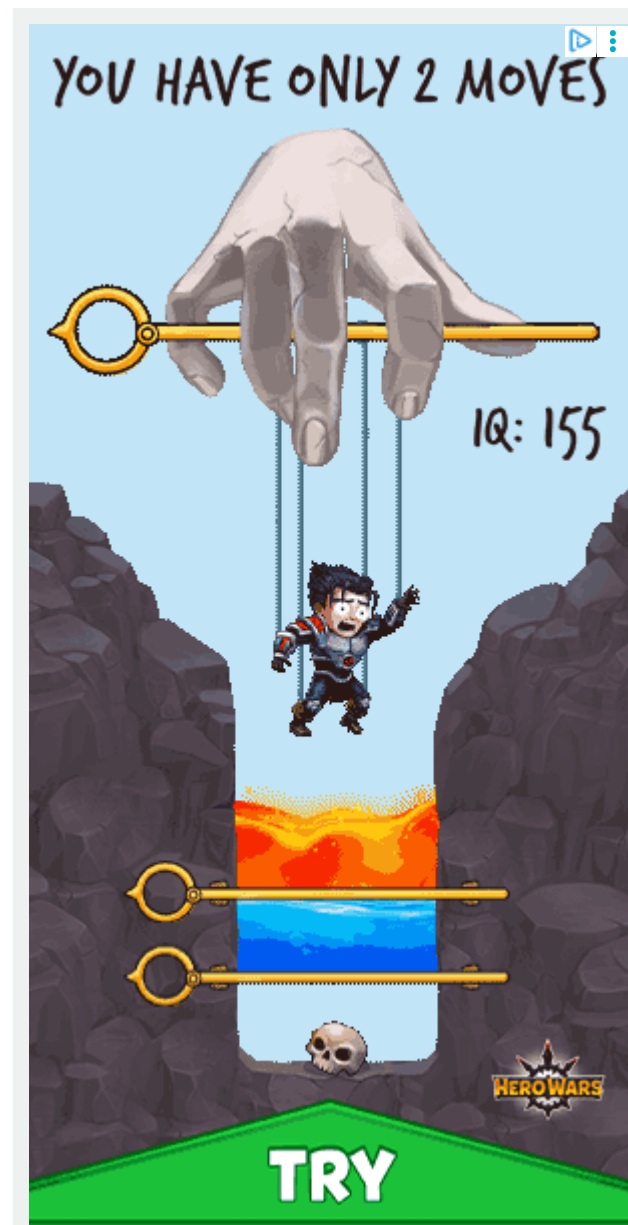
— 8:00 AM PDT · July 24, 2025

So-called AI slop, meaning [LLM](#)-generated low-quality images, videos, and text, has taken over the internet in the last couple of years, polluting [websites](#), [social media platforms](#), at least [one newspaper](#), and even [real-world events](#).

The world of cybersecurity is not immune to this problem, either. In the last year, people across the cybersecurity industry have raised concerns about AI slop bug bounty reports, meaning reports that claim to have found vulnerabilities that do not actually exist, because they were created with a [large language model](#) that simply made up the vulnerability, and then packaged it into a professional-looking writeup.

“People are receiving reports that sound reasonable, they look technically correct. And then you end up digging into them, trying to figure out, ‘oh no, where is this vulnerability?’,” Vlad Ionescu, the co-founder and CTO of [RunSybil](#), a startup that develops AI-powered bug hunters, told TechCrunch.

“It turns out it was just a hallucination all along. The technical details were just made up by the LLM,”



said Ionescu.

Ionescu, who used to work at Meta’s red team tasked with hacking the company from the inside, explained that one of the issues is that LLMs are designed to be helpful and give positive responses. “If you ask it for a report, it’s going to give you a report. And then people will copy and paste these into the bug bounty platforms and overwhelm the platforms themselves, overwhelm the customers, and you get into this frustrating situation,” said Ionescu.

“That’s the problem people are running into, is we’re getting a lot of stuff that looks like gold, but it’s actually just crap,” said Ionescu.

Just in the last year, there have been real-world examples of this. Harry Sintonen, a security researcher, revealed that the open source security project Curl received a fake report. “The attacker miscalculated badly,” Sintonen wrote [in a post on Mastodon](#). “Curl can smell AI slop from miles away.”

In response to Sintonen’s post, Benjamin Piouffle of Open Collective, a tech platform for nonprofits, [said](#)

Newsletters

[See More ↗](#)

Subscribe for the industry’s biggest tech news

TechCrunch Daily News



Every weekday and Sunday, you can get the best of TechCrunch’s coverage.

Startups Weekly



Startups are the core of TechCrunch, so get our best coverage delivered weekly.

TechCrunch Week in Review



Get the best of our coverage, delivered to your inbox every Saturday.

TechCrunch Mobility



TechCrunch Mobility is your destination for transportation news and insight.

No newsletters selected.

Latest Security
Startups AI
Venture Apps
Apple



Events
Podcasts
Newsletters



Contact Us

Do you have more information about how AI is impacting the cybersecurity industry? We'd love to hear from you. From a non-work device and network, you can contact Lorenzo Franceschi-Bicchierai securely on Signal at +1 917 257 1382, or via Telegram and Keybase @lorenzofb, or [email](#).

Michiel Prins, the co-founder and senior director of product management at HackerOne, told TechCrunch that the company has encountered some AI slop.

“We’ve also seen a rise in false positives — vulnerabilities that appear real but are generated by LLMs and lack real-world impact,” said Prins. “These low-signal submissions can create noise that undermines the efficiency of security programs.”

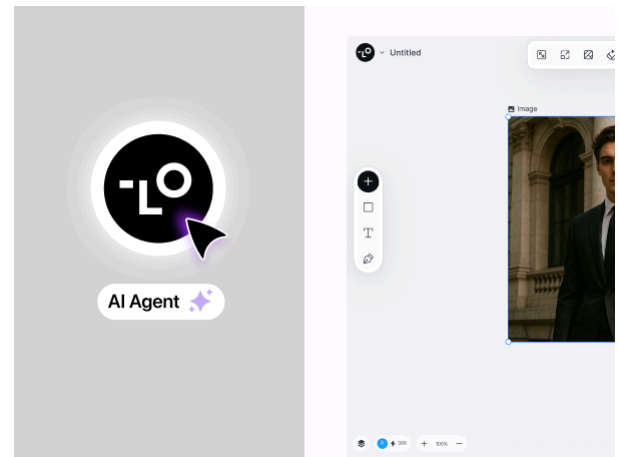
Prins added that reports that contain “hallucinated vulnerabilities, vague technical content, or other forms of low-effort noise are treated as spam.”

Casey Ellis, the founder of Bugcrowd, said that there are definitely researchers who use AI to find bugs and write the reports that they then submit to the company. Ellis said they are seeing an overall increase of 500 submissions per week.

“AI is widely used in most submissions, but it hasn’t yet caused a significant spike in low-quality ‘slop’ reports,” Ellis told TechCrunch. “This’ll probably escalate in the future, but it’s not here yet.”

Ellis said that the Bugcrowd team that analyzes submissions reviews the reports manually using

Sponsored by Lovart



★ SPONSORED

Lovart’s design agent hints at the future: AI-native brands built in minutes

established playbooks and workflows, as well as with machine learning and AI “assistance.”

To see if other companies, including those that run their own bug bounty programs, are also receiving an increase in invalid reports or reports containing non-existent vulnerabilities hallucinated by LLMs, TechCrunch contacted Google, Meta, Microsoft, and Mozilla.

Damiano DeMonte, a spokesperson for Mozilla, which develops the Firefox browser, said that the company has “not seen a substantial increase in invalid or low-quality bug reports that would appear to be AI-generated,” and the rejection rate of reports — meaning how many reports get flagged as invalid — has remained steady at five or six reports per month, or less than 10% of all monthly reports.

Mozilla’s employees who review bug reports for Firefox don’t use AI to filter reports, as it would likely be difficult to do so without the risk of rejecting a legitimate bug report,” DeMonte said in an email.

Microsoft and Meta, companies that have both bet heavily on AI, declined to comment. Google did not respond to a request for comment.

Ionescu predicts that one of the solutions to the problem of rising AI slop will be to keep investing in AI-powered systems that can at least perform a preliminary review and filter submissions for accuracy.

In fact, on Tuesday, HackerOne [launched](#) Hai Triage, a new triaging system that combines humans and AI. According to HackerOne, this new system is leveraging “AI security agents to cut through noise, flag duplicates, and prioritize real threats.” Human

analysts then step in to validate the bug reports and escalate as needed.

As hackers increasingly use LLMs and companies rely on AI to triage those reports, it remains to be seen which of the two AIs will prevail.

Topics: [AI](#) [AI](#) [ai slop](#) [bug bounty](#)

[Bug bounty programs](#) [Bugcrowd](#)

[cybersecurity](#) [Google](#) [HackerOne](#) [hackers](#)

[hacking](#) [Meta](#) [Microsoft](#) [Mozilla](#) [Security](#)



[f](#) [X](#) [in](#) [t](#) [✉](#) [🔗](#)



Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity | [X](#) [🦋](#) [@](#)

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

[View Bio](#) >

———— KEEP READING ————



IMAGE CREDITS:
ALEXANDRBOGNAT / GETTY IMAGES

SECURITY



Russian zero-day seller offers \$20M for hacking Android and iPhones

Lorenzo Franceschi-Bicchierai

— 8:59 AM PDT · September 27, 2023

A company that acquires and sells zero-day exploits — flaws in software that are unknown to the affected developer — is now offering to pay researchers \$20 million for hacking tools that would allow its customers to hack iPhones and Android devices.

On Wednesday, Operation Zero [announced](#) on its Telegram accounts and on its official account on X, formerly Twitter, that it was increasing payments for zero-days in those platforms from \$200,000 to \$20 million.

Latest in Security

[See More](#)

SECURITY



Data breach at French telecom giant Bouygues affects millions of customers

Zack Whittaker - 1 hour ago

“By increasing the premium and providing competitive plans and bonuses for contract works, we encourage the developer teams to work with our platform,” the company wrote.

Operation Zero, which is based in Russia and launched in 2021, also added that “as always, the end user is a non-NATO country.” On its official website, the company says that “our clients are Russian private and government organizations only.”

When asked why they only sell to non-NATO countries, Operation Zero CEO Sergey Zelenyuk declined to say. “No reasons other than obvious ones,” he said.

Zelenyuk also said that the bounties Operation Zero offer right now may be temporary, and a reflection of a particular time in the market, and the difficulty of hacking iOS and Android.

“The price formation of specific items is heavily dependent on availability of the product on the zero-day market,” Zelenyuk said in an email. “Full chain exploits for mobile phones are the most expensive products right now and they’re used mostly by government actors. When an actor needs a product, sometimes they’re ready to pay as much as possible to possess it before it gets into the hands of other parties.”

SECURITY



TeaOnHer, a rival Tea app for men, is leaking users’ personal data and driver’s licenses

Amanda Silberling,
Zack Whittaker
- 20 hours ago

SECURITY



Citizen Lab director warns cyber industry about US authoritarian descent

Lorenzo Franceschi-Bicchierai
- 1 day ago



Tech and VC heavyweights join the Disrupt 2025 agenda

Netflix, ElevenLabs, Wayve, Sequoia Capital — just a few of the heavy hitters joining the Disrupt 2025 agenda. They’re here to deliver the insights that fuel startup growth and sharpen your edge. Don’t miss the 20th anniversary of TechCrunch

Disrupt, and a chance to learn from the top voices in tech — grab your ticket now and save up to \$675 before prices rise on August 7.

San Francisco | October 27-29, 2025

REGISTER NOW

For at least a decade, [various companies](#) around the world have offered bounties to security researchers willing to sell the bugs and hacking techniques to exploit those flaws. Unlike traditional bug bounty platforms like Hacker One or Bugcrowd, companies like Operation Zero don't alert the vendors whose products are vulnerable, but instead sell them to government customers.

This is inherently a gray market, where prices fluctuate and the identity of the customers is often secret. But there are and have been public price lists such as the ones published by Operation Zero.

Zerodium, a company that was launched in 2015, [offers up to \\$2.5 million for a chain of bugs](#) that allows customers to hack an Android device with no interaction from the target, meaning the target doesn't have to fall for a phishing link, for example. For the same type of chain on iOS, Zerodium offers up to \$2 million, according to its website.

On modern mobile devices, thanks to improved security mitigations and defenses, hackers might need a series of zero-days to fully compromise and take control of a targeted device.

Crowdfense, a competitor based in the United Arab Emirates, [offers up to \\$3 million for the same kind of chain of bugs on Android and iOS](#).

Contact Us

Do you have more information about the market for zero-days? We'd love to hear from you. You can contact Lorenzo Franceschi-Bicchierai securely on Signal at +1 917 257 1382, or via Telegram, Keybase, and Wire @lorenzofb, or email lorenzo@techcrunch.com. You can also contact TechCrunch via [SecureDrop](#).

Referring to the bounties offered by Zerodium and Crowdfense, Zelenyuk said that he doesn't believe they will ever drop so low.

"The Zerodium price sheet is outdated, but it doesn't mean the company still buys for such low prices. They just don't need to update them, the zero-day business works fine regardless of that," said Zelenyuk.

The market for zero-days is largely unregulated. But in some countries, companies may have to obtain export licenses from the governments they operate from. This process essentially entails asking permission to sell to certain countries, which may be restricted. This has created a fractured market that is increasingly affected by politics. For example, [a recently passed law](#) in China mandates that security researchers alert the Chinese government of bugs before they alert the software makers. This law, according to experts, effectively means China is cornering the market for zero-days in an attempt to use them for intelligence purposes.

"This new regulation might enable elements in the Chinese government to stockpile reported vulnerabilities toward weaponizing them," [Microsoft said in a report from last year](#).

Corrected an earlier version of this story to remove "tenfold" from the second paragraph, this was due to an editor's error. ZW



Lovart’s design agent hints at the future: AI-native brands built in minutes

Sponsored by Lovart

Topics: [bugs](#) [cybersecurity](#) [Exclusive](#) [exploits](#)

[hacking](#) [infosec](#) [Security](#) [Zero-days](#)



Lorenzo Franceschi-Bicchierai

Senior Reporter, Cybersecurity | [X](#) [Twitter](#) [M](#)

Lorenzo Franceschi-Bicchierai is a Senior Writer at TechCrunch, where he covers hacking, cybersecurity,...

View Bio >

Loading the next article



TechCrunch

Staff

Contact Us

Advertise

Crunchboard
Jobs

Site Map

Terms of
Service

Privacy
Policy

RSS Terms of
Use

OpenAI

Perplexity

Cisco

DeepMind

Windsurf

Tech Layoffs

ChatGPT